Microsoft 365 Security Controls Implementation

> Implement the following security controls in the assigned Microsoft 365 tenant. Policies must be enabled and enforced, not left in report-only mode. Exclusions can exist for break glass accounts.

1. Multifactor authentication for administrative roles

1.1. Require multifactor authentication (MFA) for users holding administrative roles. Apply the requirement to directory roles or cover administrators through an All-users MFA policy. MFA must be mandatory, not an alternative to satisfying a different access requirement.

Method 1: Microsoft Entra Admin Center (GUI)

1. **Navigate to Conditional Access:** Requires Conditional Access Administrator or Security Administrator role. Sign in to the Microsoft Entra admin center (https://entra.microsoft.com) and browse to **Protection - Conditional Access - Policies**. Click **New policy**.
2. **Name the Policy and Assign Directory Roles:** Set the Name to **CA001: Require MFA for Administrative Roles**. Under **Users**, select **Include - Select users and groups** - check **Directory roles**. Select the following core administrative roles (at minimum, per CIS Benchmark standards):

Core Administrative Roles (CIS Benchmark Minimum)	Core Administrative Roles (Continued)
Global Administrator	Helpdesk Administrator
Application Administrator	Password Administrator
Authentication Administrator	Privileged Authentication Administrator
Billing Administrator	Privileged Role Administrator
Cloud Application Administrator	Security Administrator
Conditional Access Administrator	SharePoint Administrator
Exchange Administrator	User Administrator

3. **Exclude Break-Glass Accounts:** Prevent tenant-wide lockout. Still under **Users**, select **Exclude - Users and groups**, and select your designated emergency access (break-glass) accounts or break-glass security group.
4. **Configure Target Resources and Conditions:** Under **Target resources** (formerly Cloud apps or actions), select **Include - All resources** (formerly 'All cloud apps'). Do not exclude any applications. Under **Conditions**, leave **Client apps** set to all defaults (Browser, Mobile apps and desktop clients) so the policy applies universally across all authentication flows.

5. **Enforce Mandatory Grant Controls:** Critical: Must require MFA strictly, not as an 'OR' condition. Under **Access controls - Grant**, select **Grant access**. Check **Require multifactor authentication** (or select **Require authentication strength - Multifactor authentication / Phishing-resistant MFA**). If multiple controls are checked, ensure **Require all the selected controls** is chosen (never *Require one of the selected controls*, which makes MFA an optional alternative). Click **Select**.
6. **Enable and Enforce Policy:** Do not leave in Report-only mode. Under **Enable policy**, toggle the switch from **Report-only** to **On**. Confirm that your current administrative session isn't inadvertently locked out, and click **Create**.

2. Multifactor authentication for all users

2.2. Apply a mandatory MFA requirement to All users, covering All resources, subject to approved exclusions.

Method 1: Microsoft Entra Admin Center (GUI)

1. **Navigate to Conditional Access:** Sign in to the Microsoft Entra admin center (https://entra.microsoft.com) with at least the Conditional Access Administrator or Security Administrator role, and go to **Entra ID - Conditional Access - Policies - New policy**.
2. **Name the Policy and Assign All Users:** Set the Name to **CA001: Require MFA for All Users**. Under **Users - Include**, select **All users**.
3. **Configure Approved Exclusions:** Under **Users - Exclude**, check **Users and groups** and select your designated Break-Glass / Emergency Access accounts (or break-glass security group) so you cannot lock yourself out of the tenant. (Optional) If your lab or environment includes non-interactive service accounts or directory synchronization accounts (such as Microsoft Entra Connect Sync), exclude those specific service accounts or bind them to a trusted Named Location.
4. **Target All Resources:** Under **Target resources** (formerly Cloud apps or actions), keep the dropdown set to **Resources** (formerly 'Cloud apps') and select **Include - All resources** (formerly 'All cloud apps'). Do not configure any application exclusions (unless explicitly instructed for a lab edge case).
5. **Verify Conditions (Leave Session & Client Apps at Default):** Under **Conditions - Client apps**, ensure **Configure** is set to **Yes** and all client app types (Browser, Mobile apps and desktop clients) are checked so every modern authentication flow is covered. Under **Access controls - Session**, leave 0 controls selected (Session controls are not needed to satisfy the mandatory MFA control).
6. **Enforce Mandatory Grant Controls:** Under **Access controls - Grant**, select **Grant access**. Check **Require multifactor authentication** (or check **Require authentication strength** and select **Multifactor authentication** from the dropdown). If you combine this with any other grant check, ensure **Require all the selected controls (AND)** is selected—never *Require one of the selected controls (OR)*, which turns MFA into an optional alternative. Click **Select**.
7. **Enable and Enforce the Policy:** Under **Enable policy**, switch the toggle from **Report-only** to **On**. Review any warning prompts confirming your current account isn't locked out, and click **Create**.

3. Remediation for high user risk

3.1. Apply a user-risk policy to All users across All resources. When user risk is High, require both MFA and risk remediation. Use either adaptive risk remediation or a secure password-change requirement, not both remediation controls together. Require reauthentication Every time, covering both primary and multifactor authentication.

Method 1: Microsoft Entra Admin Center (GUI)

1. **Navigate to Conditional Access:** Sign in to the Microsoft Entra admin center (https://entra.microsoft.com) and browse to **Entra ID - Conditional Access - Policies - New policy**.
2. **Name the Policy and Assign All Users:**
   - Set the Name to **CA001: Require Remediation for High User Risk**.
   - Under **Users - Include**, select **All users**.
3. **Configure Approved Exclusions:**
   - Under **Users - Exclude**, check **Users and groups** and select your designated Break-Glass / Emergency Access accounts (or break-glass security group).
4. **Target All Resources:**
   - Under **Target resources** (formerly Cloud apps or actions), select **Include - All resources** (formerly 'All cloud apps').
   - Ensure no applications are excluded.
5. **Configure the User Risk Condition:**
   - Under **Conditions**, click **User risk**.
   - Toggle **Configure** to **Yes**.
   - Check **High** only (leave Medium and Low unchecked).
   - Click **Done**.
6. **Enforce Grant Controls (MFA + Single Remediation Control with AND):**
   - Under **Access controls**, click **Grant** and select **Grant access**.
   - Check **Require multifactor authentication**.
   - Select ONE of the following remediation controls (do not select both together):
     - **Option A (Standard / Built-in):** Check **Require password change** (note: in the Entra portal, checking Require password change automatically checks Require multifactor authentication).
     - **Option B (If Adaptive Risk Remediation preview is present in your tenant):** Check the adaptive risk remediation control instead of Require password change, along with Require multifactor authentication.
   - At the bottom of the Grant pane, under **For multiple controls**, ensure **Require all the selected controls** (AND operator) is selected.

7. ○ Click **Select**.
8. **Configure Session Controls (Sign-in Frequency = Every Time):**
   - Under **Access controls**, click **Session**.
   - Check **Sign-in frequency**.
   - Select the radio button for **Every time** (this forces reauthentication covering both primary and multifactor authentication whenever high user risk is active).
   - Click **Select**.
9. **Enable and Enforce the Policy:**
   - Under **Enable policy**, switch the toggle from **Report-only** to **On**.
   - Click **Create**.

4. Prevent ordinary-user application consent

4.1. Prevent ordinary users from granting new consent to applications that access organizational data on their behalf. This includes limited self-consent for verified publishers or low-risk permissions; ordinary-user self-consent must be disabled.

Method 1: Microsoft Entra Admin Center (GUI)

1. **Navigate to Enterprise Applications Consent Settings:** Sign in to the Microsoft Entra admin center (https://entra.microsoft.com) as a Global Administrator or Privileged Role Administrator, and browse to **Identity (or Entra ID) - Applications - Enterprise applications**.
2. **Open User Consent Settings:** In the left navigation menu under **Security**, select **Consent and permissions - User consent settings**.
3. **Disable All Ordinary-User Application Consent:** Under **User consent for applications**, select the first radio button:
   - **Do not allow user consent** (An administrator will be required for all apps.)
   - **Critical Note:** Do not select *Allow user consent for apps from verified publishers, for selected permissions (Recommended)*, as your requirement explicitly forbids limited self-consent for verified publishers or low-risk permissions.
4. **Save the Configuration:** Click **Save** at the top of the pane to immediately enforce the restriction across the tenant.

5. Invited-participant Teams lobby bypass

5.1. Configure the Global (Org-wide default) Teams meeting policy so that Who can bypass the lobby defaults to People who were invited.

Method 1: Microsoft Teams Admin Center (GUI)

1. **Navigate to Teams Meeting Policies:** Sign in to the Microsoft Teams admin center (https://admin.teams.microsoft.com) as a Teams Administrator or Global Administrator, and go to **Meetings - Meeting policies** in the left navigation pane.
2. **Select the Global Policy:** Under **Manage policies**, click on **Global (Org-wide default)** to edit the tenant-wide default meeting policy.
3. **Configure Lobby Bypass Settings:**
   - Scroll down to the **Meeting join & lobby** section.
   - Locate **Who can bypass the lobby**.
   - Change the dropdown value to **People who were invited**.
   - **Note:** In the Teams admin center UI, selecting *People who were invited* automatically turns off and grays out *People dialing in can bypass the lobby*, ensuring uninvited dial-in users are also held in the lobby.
4. **Save the Policy:** Scroll to the bottom of the page and click **Save** (and click **Confirm** if prompted that changes will take effect for all users assigned to the Global policy).

6. Organizer-only default Teams presenters

6.1. Configure the Global (Org-wide default) Teams meeting policy so that Who can present defaults to Only organizers and co-organizers. Other participants must join as attendees by default.

Method 1: Microsoft Teams Admin Center (GUI)

1. **Navigate to Teams Meeting Policies:** Sign in to the Microsoft Teams admin center (https://admin.teams.microsoft.com) as a Teams Administrator or Global Administrator, and go to **Meetings - Meeting policies** in the left navigation pane.
2. **Select the Global Policy:** Under **Manage policies**, click on **Global (Org-wide default)** to edit the tenant-wide default meeting policy.
3. **Disable Anonymous Meeting Join:**
   - Scroll to the **Meeting join & lobby** section.
   - Locate **Anonymous users can join a meeting**.
   - Toggle the switch to **Off**.
   - **Critical Distinction:** Do not confuse this policy setting with *Anonymous users and dial-in callers can start a meeting*, and do not rely solely on *Who can bypass the lobby = People who were invited* to hold anonymous users in the lobby. Setting *Anonymous users can join a meeting* to **Off** outright blocks unauthenticated participants from joining or even entering the meeting lobby.
4. **Save the Policy:** Scroll to the bottom of the page and click **Save** (and click **Confirm** if prompted).

7. Self-service password reset for all users

7.1. Set Self service password reset enabled to All for the tenant. Enabling reset only for selected users or a selected group does not meet this requirement.

Method 1: Microsoft Entra Admin Center (GUI)

1. **Navigate to Password Reset Settings:** Sign in to the Microsoft Entra admin center (https://entra.microsoft.com) as a Global Administrator or Authentication Policy Administrator, and browse to **Identity (or Entra ID) - Users - Password reset** in the left navigation menu.
2. **Select Properties:** In the **Password reset** menu, ensure **Properties** is selected under **Manage**.
3. **Enable SSPR for All Users:**
   - Locate the **Self service password reset enabled** toggle.
   - Click **All** (choosing *Selected* and assigning a group does not satisfy this control).
4. **Save the Configuration:** Click **Save** at the top of the pane to immediately enforce SSPR across the entire tenant.

Install and Load Invoke-MgGraphRequest in PowerShell

Run the following commands in the exact same PowerShell window (or machine) where the grading/verification script is running:

```
# 1. Trust the PowerShell Gallery and install the core Microsoft Graph
Authentication module
Set-PSRepository -Name "PSGallery" -InstallationPolicy Trusted
Install-Module -Name Microsoft.Graph.Authentication -Scope CurrentUser -Force -
AllowClobber

# 2. Import the module so Invoke-MgGraphRequest is immediately available
Import-Module Microsoft.Graph.Authentication -Force

# 3. Verify that the cmdlet is now recognized
Get-Command Invoke-MgGraphRequest
```

Install MicrosoftTeams Globally (AllUsers)

Open an Administrator PowerShell window (right-click PowerShell -> Run as Administrator) and run:

```
# 1. Ensure TLS 1.2 is enabled and PSGallery is trusted
[Net.ServicePointManager]::SecurityProtocol = [Net.SecurityProtocolType]::Tls12
Set-PSRepository -Name "PSGallery" -InstallationPolicy Trusted

# 2. Install MicrosoftTeams for ALL users on the machine so any script/process can
find it
Install-Module -Name MicrosoftTeams -Scope AllUsers -Force -AllowClobber

# 3. Import it into the current session and verify
Import-Module MicrosoftTeams -Force
Get-Command Disconnect-MicrosoftTeams
```